

UNDERSTANDING SECURITY ASSESSMENT

SECURITY ASSESSMENT

Objective:

To evaluate systems, networks, or applications to identify security weaknesses without using paid tools.

Definition:

A structured process of identifying vulnerabilities, analyzing risks, and recommending improvements using recognized security frameworks.

Framework Example:

National Institute of Standards and Technology (NIST)

NIST provides guidelines such as:

- Risk assessment methods
- Security control standards
- Technical security testing procedures

Types of Security Testing

A) Vulnerability Assessment (VA)

Definition:

A process of scanning systems to identify known vulnerabilities.

Purpose:

To detect weaknesses but not exploit them.

Tool Example:

OpenVAS (Open-source tool)

Key Points:

- Identifies outdated software
- Detects open ports
- Checks misconfigurations
- Provides CVSS risk scores
- Generates vulnerability reports

B) Penetration Testing (Pentesting)

Definition:

Simulating real-world cyberattacks to test system security.

Purpose:

To exploit vulnerabilities and demonstrate real impact.

Platform Example:

Kali Linux

Common Tools:

- Nmap – Network scanning
- Metasploit – Exploitation

Phases:

1. Reconnaissance
2. Scanning
3. Exploitation
4. Reporting

C) Compliance Testing

Definition:

Checking whether systems follow required security standards.

Purpose:

Ensure adherence to regulatory and best practice requirements.

Standard Example:

Center for Internet Security – CIS Benchmarks

Key Activities:

- Use security configuration checklists
- Verify password policies
- Check firewall settings
- Validate logging and monitoring

VAPT METHODOLOGY

Objective

To follow a structured approach for conducting Vulnerability Assessment and Penetration Testing (VAPT).

Phases of VAPT

Planning Phase

Purpose:

Define scope, objectives, and rules of engagement before testing.

Activities:

- Identify target systems (IP, domains, applications)
- Get written authorization
- Define testing type (Black box / White box / Grey box)
- Set timeline and limitations

Tool Example:

Dradis CE – Used for organizing findings and managing test documentation.

Discovery Phase (Information Gathering)

Purpose:

Collect information about the target system.

Activities:

- Identify live hosts
- Scan open ports
- Detect running services
- Identify web application vulnerabilities

Tools Used:

- Nmap – Network scanning and service detection
- OWASP ZAP – Web application vulnerability scanning

Attack Phase (Exploitation)

Purpose:

Exploit identified vulnerabilities to test real impact.

Activities:

- Use exploits
- Gain system access
- Escalate privileges
- Demonstrate risk impact

Tool Example:

Metasploit Framework – Exploitation and payload delivery tool.

SECURITY STANDARDS & COMPLIANCE

Objective

To ensure organizations align with **legal, regulatory, and industry security standards** to protect data and reduce risk.

Security Compliance

Security compliance means following **established rules, laws, and frameworks** to safeguard sensitive information and systems.

It ensures:

- Data protection
- Risk management
- Legal adherence
- Customer trust

Important Security Standards

General Data Protection Regulation (GDPR)

- Protects personal data of EU citizens
- Requires user consent for data collection
- Mandates breach notification within 72 hours
- Heavy penalties for non-compliance

Health Insurance Portability and Accountability Act (HIPAA)

- Protects healthcare information (PHI)
- Requires administrative, technical, and physical safeguards
- Ensures confidentiality and integrity of medical data

ISO/IEC 27001

- International standard for Information Security Management Systems (ISMS)
- Focuses on risk assessment and risk treatment
- Requires security policies and continuous improvement

RISK ASSESSMENT BASICS

Objective

To prioritize vulnerabilities using structured scoring systems

Risk Assessment

Risk Assessment is the process of:

- Identifying vulnerabilities
- Evaluating their severity
- Prioritizing them for remediation

It helps organizations focus on **critical risks first**.

CVSS (Common Vulnerability Scoring System)

Tool Used:

National Vulnerability Database (NVD) CVSS Calculator

Purpose:

To assign a numerical severity score (0–10) to vulnerabilities.

CVSS Score Range:

Score	Severity
0.0 – 3.9	Low
4.0 – 6.9	Medium
7.0 – 8.9	High
9.0 – 10	Critical

CVSS Evaluates:

- Attack Vector (Network/Local)
- Attack Complexity
- Privileges Required
- User Interaction
- Impact on Confidentiality, Integrity, Availability

Higher score → Higher priority for fixing.

COMMON VULNERABILITIES

Objective

To identify common security flaws in networks and web applications using lab environments and tools.

Network Vulnerabilities

Definition

Weaknesses in network configurations or services that attackers can exploit.

Common Examples:

- Open unnecessary ports
- Weak firewall rules
- Default credentials
- Outdated services
- Misconfigured DNS or SMB

Tool Used:

Nmap

Purpose of Nmap:

- Scan open ports
- Identify running services
- Detect OS versions
- Find exposed services

Web Vulnerabilities

Definition

Security flaws in web applications that allow unauthorized access or data manipulation.

Common Examples:

- SQL Injection (SQLi) – Injecting malicious SQL queries
- Cross-Site Scripting (XSS) – Injecting malicious scripts into web pages
- Broken Authentication
- Security Misconfiguration

Practice Platform:

OWASP Juice Shop

Purpose:

- Safe environment to practice web attacks
- Learn OWASP Top 10 vulnerabilities
- Understand exploitation techniques

How to Learn (Practical Labs)

Metasploitable

- Deliberately vulnerable Linux virtual machine
- Practice network scanning and exploitation
- Safe lab for beginners

VulnHub

- Download vulnerable machines
- Practice real-world attack scenarios
- Improve penetration testing skills

Documentation Fundamentals

Objective

To create clear, structured, and professional security reports using documentation tools.

Importance of Documentation

Documentation is a critical part of VAPT because:

- It communicates findings to management
- Provides proof of vulnerabilities
- Suggests remediation steps
- Acts as legal evidence of testing

Good documentation should be:

- Clear
- Structured
- Evidence-based
- Professional

Tools for Documentation

Dradis CE

Purpose:

- Centralized collaboration during VAPT
- Organize findings
- Generate professional reports
- Store evidence and screenshots

Used mainly in team-based penetration testing.

CherryTree

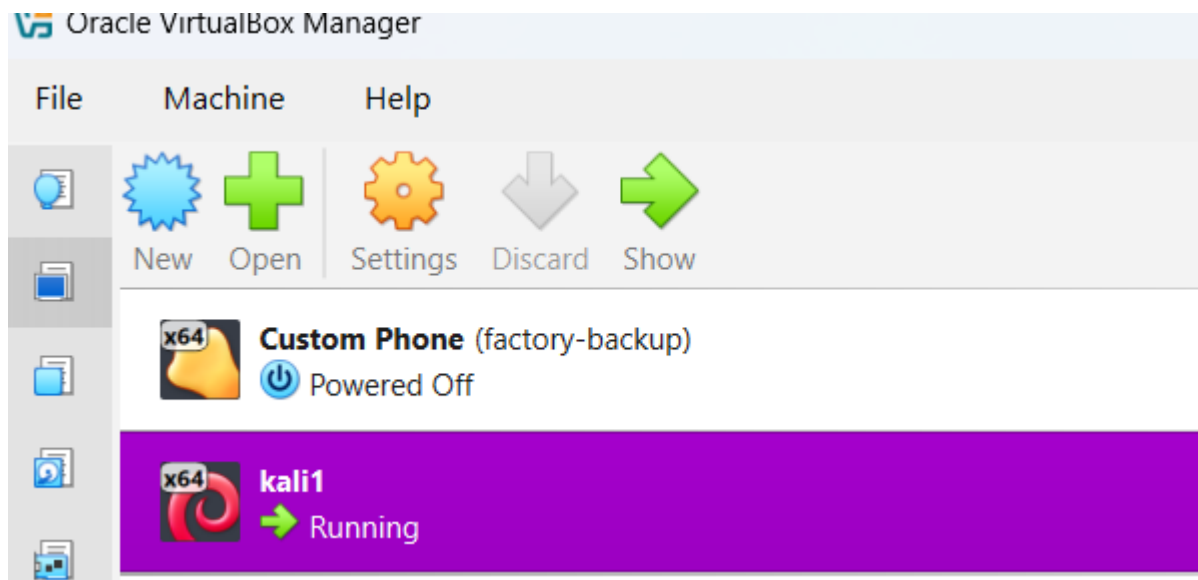
Purpose:

- Structured technical note-taking
- Store commands used
- Save payloads and test results
- Organize findings in tree format

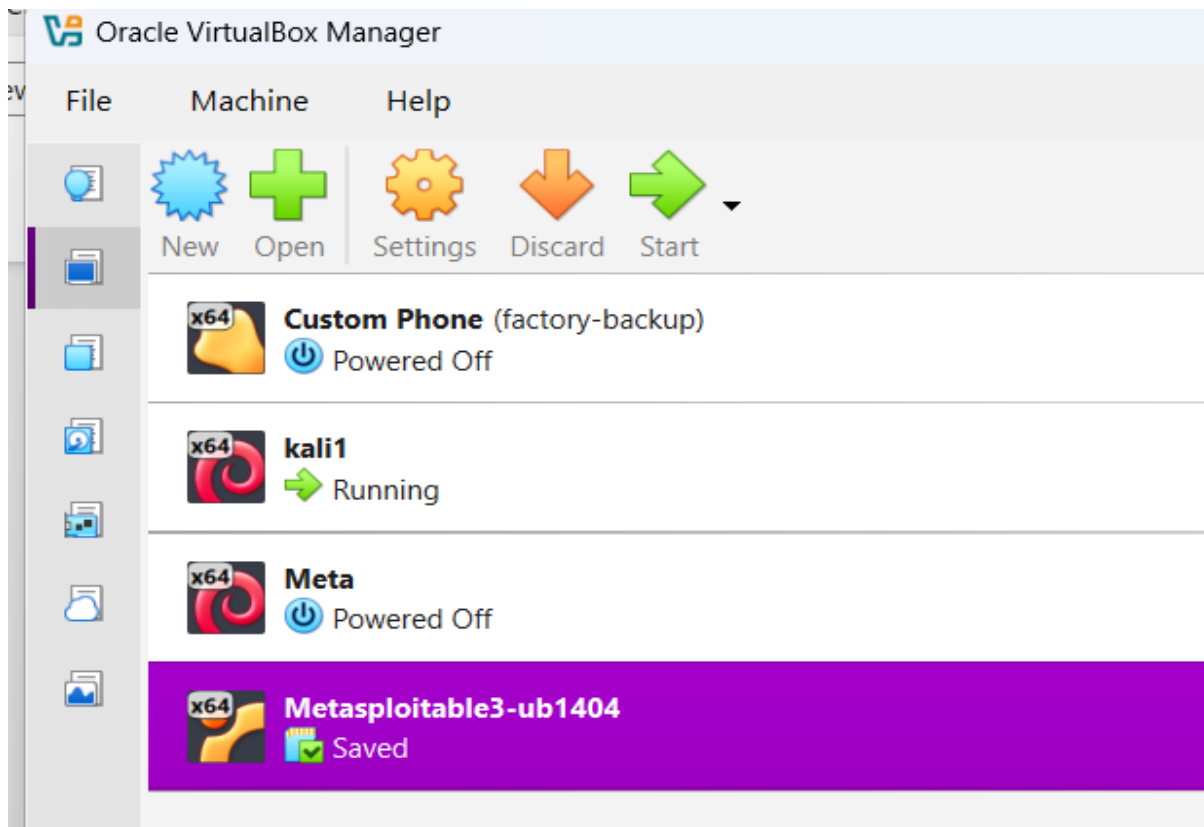
Very useful during live testing to avoid missing details.

Practical Application

Install Kali Linux

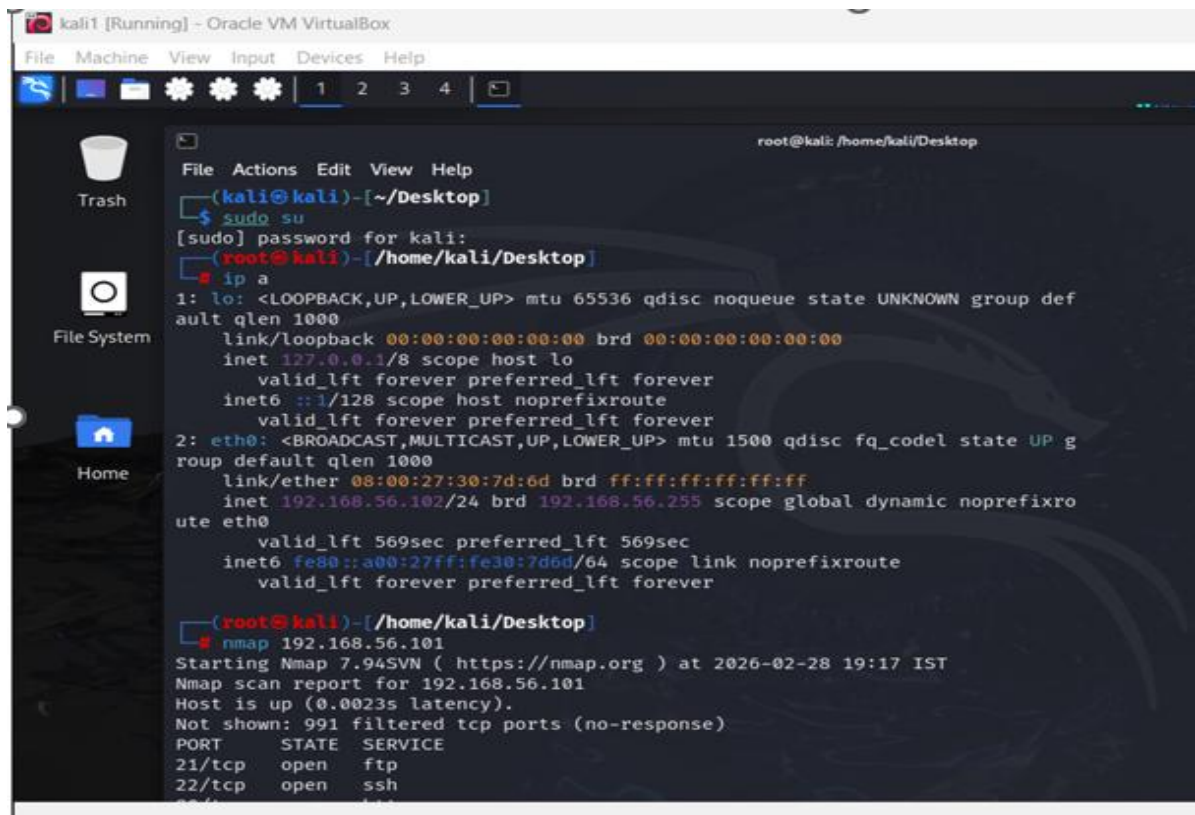


Metasploitable 3



VirtualBox to host VMs

Kali Linux – IP 192.168.56.102

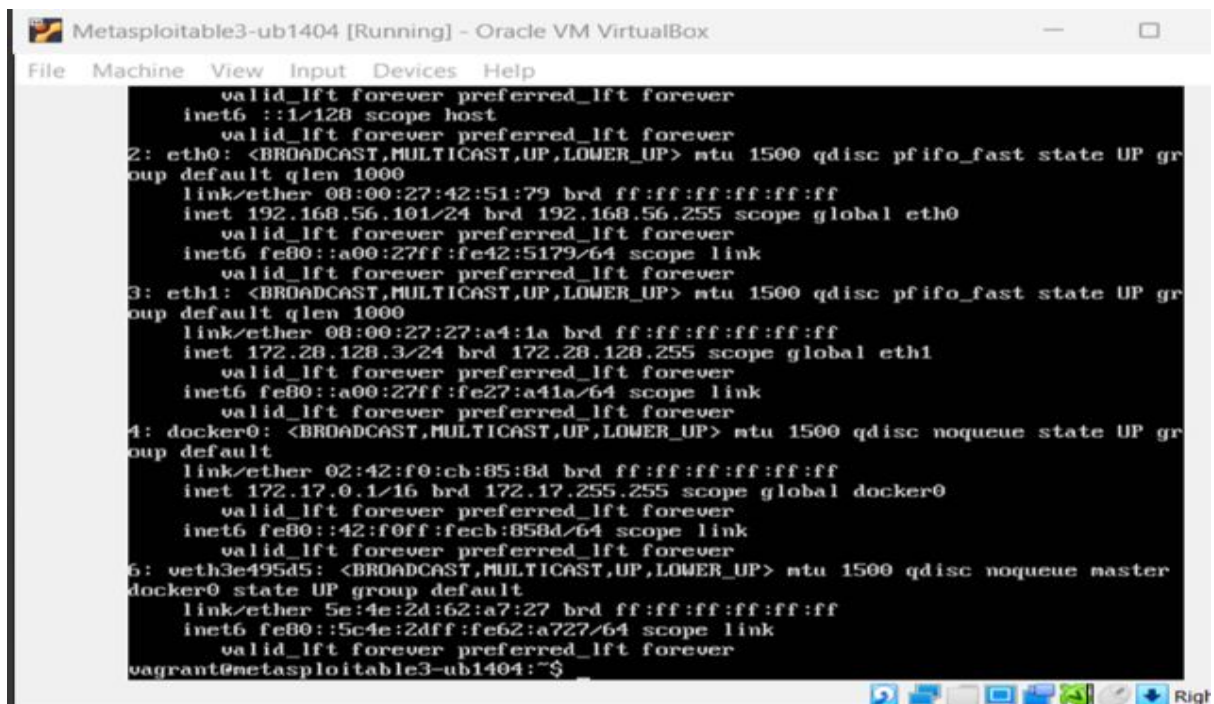


```
kali1 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4

root@kali: /home/kali/Desktop

File Actions Edit View Help
(kali@kali)~[~/Desktop]
$ sudo su
[sudo] password for kali:
(root@kali)~[~/home/kali/Desktop]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group def
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP g
    link/ether 08:00:27:30:7d:6d brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.102/24 brd 192.168.56.255 scope global dynamic noprefixro
        valid_lft 569sec preferred_lft 569sec
    inet6 fe80::a00:27ff:fe30:7d6d/64 scope link noprefixroute
        valid_lft forever preferred_lft forever
(root@kali)~[~/home/kali/Desktop]
$ nmap 192.168.56.101
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-02-28 19:17 IST
Nmap scan report for 192.168.56.101
Host is up (0.0023s latency).
Not shown: 991 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
```

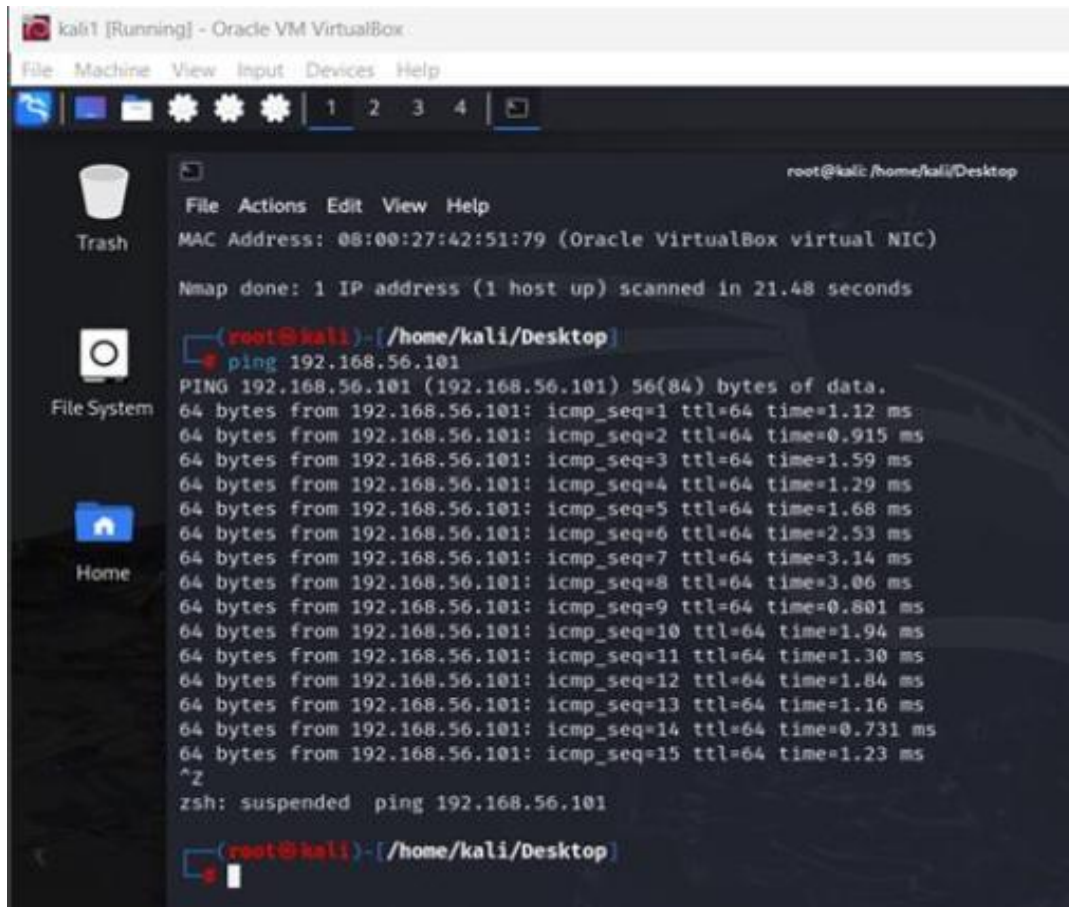
Metasploitable3 -IP 192.168.56.101



```
Metasploitable3-ub1404 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help

valid_lft forever preferred_lft forever
inet6 ::1/128 scope host
valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP gr
    link/ether 08:00:27:42:51:79 brd ff:ff:ff:ff:ff:ff
    inet 192.168.56.101/24 brd 192.168.56.255 scope global eth0
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe42:5179/64 scope link
        valid_lft forever preferred_lft forever
3: eth1: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP gr
    link/ether 08:00:27:27:a4:1a brd ff:ff:ff:ff:ff:ff
    inet 172.28.128.3/24 brd 172.28.128.255 scope global eth1
        valid_lft forever preferred_lft forever
    inet6 fe80::a00:27ff:fe27:a41a/64 scope link
        valid_lft forever preferred_lft forever
4: docker0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue state UP gr
    link/ether 02:42:f0:cb:85:8d brd ff:ff:ff:ff:ff:ff
    inet 172.17.0.1/16 brd 172.17.255.255 scope global docker0
        valid_lft forever preferred_lft forever
    inet6 fe80::42:f0ff:feeb:858d/64 scope link
        valid_lft forever preferred_lft forever
5: veth3e495d5: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc noqueue master
    link/ether 5e:4e:2d:62:a7:27 brd ff:ff:ff:ff:ff:ff
    inet6 fe80::5c4e:2dff:fe62:a727/64 scope link
        valid_lft forever preferred_lft forever
vagrant@metasploitable3-ub1404:~$
```

Ping – Metasploit table 3 IP



```
kali1 [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
1 2 3 4

root@kali: /home/kali/Desktop
File Actions Edit View Help
MAC Address: 08:00:27:42:51:79 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 21.48 seconds

(root@kali)-[/home/kali/Desktop]
* ping 192.168.56.101
PING 192.168.56.101 (192.168.56.101) 56(84) bytes of data:
64 bytes from 192.168.56.101: icmp_seq=1 ttl=64 time=1.12 ms
64 bytes from 192.168.56.101: icmp_seq=2 ttl=64 time=0.915 ms
64 bytes from 192.168.56.101: icmp_seq=3 ttl=64 time=1.59 ms
64 bytes from 192.168.56.101: icmp_seq=4 ttl=64 time=1.29 ms
64 bytes from 192.168.56.101: icmp_seq=5 ttl=64 time=1.68 ms
64 bytes from 192.168.56.101: icmp_seq=6 ttl=64 time=2.53 ms
64 bytes from 192.168.56.101: icmp_seq=7 ttl=64 time=3.14 ms
64 bytes from 192.168.56.101: icmp_seq=8 ttl=64 time=3.06 ms
64 bytes from 192.168.56.101: icmp_seq=9 ttl=64 time=0.801 ms
64 bytes from 192.168.56.101: icmp_seq=10 ttl=64 time=1.94 ms
64 bytes from 192.168.56.101: icmp_seq=11 ttl=64 time=1.30 ms
64 bytes from 192.168.56.101: icmp_seq=12 ttl=64 time=1.84 ms
64 bytes from 192.168.56.101: icmp_seq=13 ttl=64 time=1.16 ms
64 bytes from 192.168.56.101: icmp_seq=14 ttl=64 time=0.731 ms
64 bytes from 192.168.56.101: icmp_seq=15 ttl=64 time=1.23 ms
^Z
zsh: suspended ping 192.168.56.101

(root@kali)-[/home/kali/Desktop]
```

Vulnerability Scanning

Host: 192.168.56.101

Operating System: Ubuntu 14.04

Scan Profile: Full and Fast

Scan Duration: 28 minutes

Total Vulnerabilities Found: 186

CRITICAL VULNERABILITIES

MS17-010 – EternalBlue

Name: Microsoft Windows SMB Remote Code Execution Vulnerability

OID: 1.3.6.1.4.1.25623.1.0.900123

Severity: 10.0 (Critical)

CVSS v2 Base Score: 10.0

CVSS v3 Base Score: 9.8

CVE: CVE-2017-0144

Port: 445/tcp

Summary:

The remote host is vulnerable to MS17-010 (EternalBlue).

An attacker can execute arbitrary code via crafted SMB packets.

Impact:

Complete system compromise.

Solution:

Apply Microsoft security patch MS17-010.

HIGH Severity

VSFTPD 2.3.4 Backdoor

Name: VSFTPD Backdoor Detection

Severity: 9.0 (High)

CVE: CVE-2011-2523

Port: 21/tcp

Summary:

VSFTPD version 2.3.4 contains a malicious backdoor.

Impact:

Allows attackers to gain shell access.

Solution:

Upgrade VSFTPD to latest secure version.

MEDIUM Severity

MySQL Anonymous Login Enabled

Name: MySQL Anonymous Access

Severity: 5.0 (Medium)

Port: 3306/tcp

Summary:

Anonymous login is enabled on MySQL server.

Impact:

Unauthorized database access possible.

Solution:

Disable anonymous accounts.

LOW Severity

SSH Weak MAC Algorithms

Name: SSH Weak MAC Algorithms Enabled

Severity: 2.6 (Low)

Port: 22/tcp

Summary:

SSH server allows weak MAC algorithms.

Impact:

Possible cryptographic weaknesses.

Solution:

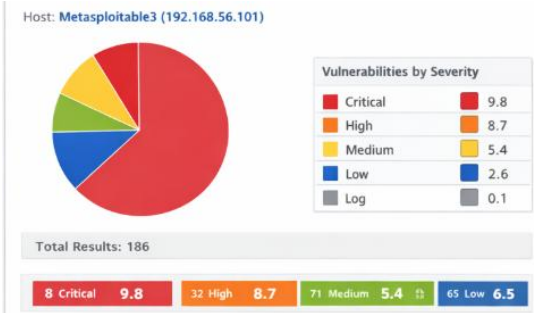
Update SSH configuration.

Report Summary

Severity	Count
Critical	8
High	32
Medium	71
Low	65
Log	10

Vulnerability Tracking Sheet

Host IP	Port	Service	Vulnerability	CVE ID	CVSS	Severity	Description	Recommendation
192.168.56.101	21	FTP (vsftpd 2.3.4)	VSFTPD Backdoor	CVE-2011-2523	9.0	High	Backdoored FTP service allows remote shell access	Upgrade to latest VSFTPD version
192.168.56.101	22	SSH	Weak MAC Algorithms	—	2.6	Low	Weak cryptographic algorithms enabled	Disable weak MAC algorithms
192.168.56.101	445	SMB	MS17-010 (EternalBlue)	CVE-2017-0144	9.8	Critical	Remote code execution via SMB	Apply MS17-010 patch
192.168.56.101	3306	MySQL	Anonymous Login Enabled	—	5.0	Medium	Anonymous DB access allowed	Disable anonymous account



Finding 1: MS17-010 – SMB Remote Code Execution

Host: 192.168.56.101

Port: 445/TCP

Service: SMB

Severity: Critical

CVSS Score: 9.8

CVE: CVE-2017-0144

Description:

The target system is vulnerable to MS17-010, which allows remote attackers to execute arbitrary code via crafted SMB packets.

Impact:

An unauthenticated attacker can gain complete control of the system.

Recommendation:

Apply Microsoft security patch MS17-010 immediately.

3x3 Risk Matrix

Vulnerability	Likelihood	Impact	Risk Score (L × I)	Risk Level
MS17-010	3	3	9	Critical
VSFTPD Backdoor	3	3	9	Critical
MySQL Anonymous	2	2	4	Medium
SSH Weak MAC	1	1	1	Low